Proposal & working paper · 26 October 2026

Using cloud services through FedRAMP

A signed CSA for the cloud service. A separate ATO for the agency system.

This report reviews a proposed agency workflow and turns it into an eight-step workbook. It is an independent analysis, not official FedRAMP guidance or an authorization.

The core premise

The proposal is a new FedRAMP-specific Cloud Service Authorization (CSA) process that agencies would follow for cloud services used by their federal information systems. Each CSA would be a distinct signed agency decision, referenced from SA-9, SA-4, and other applicable controls. The agency would separately authorize its federal information system through the FISMA ATO process.

The FedRAMP Act's process and reuse authorities, M-24-15, and NIST's external-service model provide a basis for evaluating this design. The CSA would operate within the agency system's lifecycle, with its own decision scope and signed record. Agency monitoring would connect service evidence and CSA conditions to the system's continued authorization.

What would be new: a FedRAMP-defined agency CSA procedure and signed decision, separate from the agency system ATO and from the provider's FedRAMP authorization or certification. SA-9, SA-4, and other control records would reference the CSA. It is not merely an annex renamed as an authorization, and it is not the existing NIST ATU.

Published FedRAMP guidance supports reuse and agency system authorization. The cited guidance does not establish the distinct CSA proposed here. The report separates that proposed process from existing requirements and identifies what FedRAMP would need to define.

> **FEDRAMP PROGRAM GUIDANCE**
>
> Agencies use FedRAMP Certifications as reusable security evidence, but each agency still authorizes its own federal information systems. FedRAMP certifies the cloud service offering; the agency authorizing official accepts risk for the agency's specific use of that service, including the information processed, the configuration selected, the integrations enabled, and the controls the agency is responsible for operating.
>
> Using a FedRAMP Certified Cloud Service · Retrieved 2026-10-26
> Opening paragraph; retrieved October 26, 2026 · Read original

FEDRAMP & PROVIDER

Assurance about the offering

Assessment evidence, certification boundary, provider responsibilities, secure configuration guidance, findings, and ongoing service evidence.

AGENCY

Risk of the actual use

Under the proposal: a signed CSA for each cloud service and a separate system ATO, covering information, mission, customer controls, integrations, agreements, and continued use or exit.

Evidence informs the agency decision
Agency concerns feed back to FedRAMP

This is a responsibility map, not a legal boundary excluding the provider from applicable requirements. See SA-9 in steps 3 and 8, and M-24-15 in steps 7 and 8.

> **Point of concern · Commercial does not automatically mean outside federal system scope**
>
> The workflow does not depend on a blanket claim that commercial cloud services cannot operate on the government's behalf. "External" in SA-9 concerns control implementation and assessment. FISMA, A-130, and FedRAMP have their own wording and scope. Record the facts and applicable responsibilities instead of using the service's commercial status as an exemption.

Review of the six proposed steps

Step 4 below reflects the clarified proposal: agencies perform a separate, signed CSA under a new FedRAMP process. Step 5 remains the agency system's FISMA ATO. The expanded workbook adds preparation, agreements, control references, and connected monitoring.

1. ### Begin with information and use

   Aligned. Add ownership, information flows, non-security obligations, and a FedRAMP scope determination. See workbook step

2. ### Categorize the agency system and tailor controls

   Aligned. Derive the category from information and mission harm; define a real boundary and allocate responsibilities. See workbook step

3. ### Evaluate external services using FedRAMP evidence

   Aligned with conditions. Presume provider assessment adequate; document fit and customer work without repeating the assessment. See workbook step

4. ### Perform a Cloud Service Authorization through a new FedRAMP process

   Proposed new procedure. Agencies would issue a distinct signed CSA for cloud services used by their agency information system, document the applicable requirements, and reference the CSA from SA-9, SA-4, and other controls. The system ATO remains separate. See workbook step

5. ### Implement, assess, and authorize the agency system

   Aligned. Complete the system's FISMA assessment and ATO, using signed CSAs as supporting decisions and assessing agency implementation and integrations. See workbook step

6. ### Monitor the service and agency system

   Aligned if connected. Feed FedRAMP evidence into agency monitoring, ongoing risk acceptance, and change/exit decisions. See workbook step

---

What the law lets FedRAMP standardize

The 2022 Act gives GSA a program and process mandate. M-24-15 replaces the 2011 FedRAMP memorandum and assigns FedRAMP the process and criteria for a FedRAMP authorization. Those authorities support a reusable service-assurance process, templates, boundary guidance, and monitoring procedures. They are the basis for considering the proposed agency CSA. The general process mandate does not, by itself, specify this new signed agency decision; its adoption would need to follow the respective GSA, Board, and OMB roles and remain consistent with the governing requirements.

> **LAW**
>
> There is established within the General Services Administration the Federal Risk and Authorization Management Program. The Administrator, subject to section 3614, shall establish a Government-wide program that provides a standardized, reusable approach to security assessment and authorization for cloud computing products and services that process unclassified information used by agencies.
>
> FedRAMP Authorization Act in P.L. 117-263 · 2022-12-23
> 44 USC 3608; 136 Stat. 3450 · Read original · PDF p. 1056

> **LAW**
>
> "(1) in consultation with the Secretary, develop, coordinate, and implement a process to support agency review, reuse, and standardization, where appropriate, of security assessments of cloud computing products and services, including, as appropriate, oversight of continuous monitoring of cloud computing products and services, pursuant to guidance issued by the Director pursuant

to section 3614;
“(2) establish processes and identify criteria consistent with guidance issued by the Director under section 3614 to make a cloud computing product or service eligible for a FedRAMP authorization and validate whether a cloud computing product or service has a FedRAMP authorization;
“(3) develop and publish templates, best practices, technical assistance, and other materials to support the authorization of cloud computing products and services and increase the speed, effectiveness, and transparency of the authorization process, consistent with standards and guidelines established by the Director of the National Institute of Standards and Technology and relevant statutes;

FedRAMP Authorization Act in P.L. 117-263 · 2022-12-23
44 USC 3609(a)(1)–(3); 136 Stat. 3450 · Read original · PDF p. 1056

OMB POLICY

As a result, this memorandum rescinds the Federal CIO’s December 8, 2011 memorandum, and replaces it with an updated vision, scope, and governance structure for FedRAMP that is responsive to developments in Federal cybersecurity and substantial changes to the commercial cloud marketplace that have occurred since the program was established.

Modernizing the Federal Risk and Authorization Management Program (FedRAMP) · 2024-07-25
Introduction, p. 1 · Read original · PDF p. 1

OMB POLICY

FedRAMP is responsible for defining the processes and criteria that must be met in order for a cloud product or service to receive a FedRAMP authorization.

Modernizing the Federal Risk and Authorization Management Program (FedRAMP) · 2024-07-25
§IV(b), p. 7; footnote 15 cites 44 USC 3609(a)(2) · Read original · PDF p. 7

What those changes preserve

The Act expressly preserves agency FISMA responsibility in §3613(e)(2), quoted in step 4. M-24-15 footnote 7 preserves other information-management, records, privacy, and cybersecurity obligations, quoted in step 7. Neither source supplies a blanket repeal of A-130 or NIST. The Act also requires consistency with NIST standards and guidelines and relevant statutes.

LAW

Each agency shall develop, document, and implement an agency-wide information security program to provide information security for the information and information systems that support the operations and assets of the agency, including those provided or managed by another

agency, contractor, or other source, that includes—

Federal Information Security Modernization Act · 2014-12-18
44 USC 3554(b); 128 Stat. 3079 · Read original · PDF p. 7

NIST GUIDANCE

FISMA and OMB policy require external providers that process, store, or transmit federal information or operate information systems on behalf of the federal government to meet the same security and privacy requirements as federal agencies. Federal security and privacy requirements also apply to external systems storing, processing, or transmitting federal information and any services provided by or associated with the external system.

SP 800-37 Rev. 2: Security and Privacy RMF · 2018-12-20
Appendix G, printed p. 159 · Read original · PDF p. 178

Point of concern · Apply newer reuse rules to older NIST procedures

SP 800-37 Rev. 2 Appendix F allows requests for additional controls or information when evaluating a shared service. For FedRAMP use, that older general procedure must be read with the later statutory presumption of adequacy, demonstrable-need provision, M-24-15, and current FedRAMP notification rules. Older discretion is not permission to duplicate the provider assessment.

Three decisions to keep distinct

FedRAMP authorization / certification

The program's determination about an offering. The Act and M-24-15 use "authorization"; the current 2026 program pages use "certification." Preserve those terms in citations and identify the specific package/status being reused.

Agency Cloud Service Authorization — proposed

A distinct signed agency decision under a new FedRAMP process for a cloud service used by an identified agency information system. It documents requirements, evidence, responsibilities, conditions, and accepted service-use risk. SA-9, SA-4, and other applicable system control records reference its identifier and version.

Agency system ATO

The separate authorization of the federal information system under the FISMA framework. It relies on the signed CSAs and other evidence while assessing the system as a whole. Existing NIST ATU guidance is quoted later for comparison; an ATU is not the CSA proposed here.

> **FEDRAMP PROGRAM GUIDANCE**
>
> The resulting Authorization to Operate applies to the agency information system and its use of the cloud service.
>
> Initial Agency Authorization · Retrieved 2026-10-26
> Introduction; retrieved October 26, 2026 · Read original

Agency-use workbook

Use one worksheet per agency use and service; link related records when a system uses several services. Work through the eight records below. Steps 2–5 are iterative: evidence or design changes can send you back. The proposed CSA and the agency system ATO have separate scopes. For a new system, operational use waits for its ATO. Within an existing ATO lifecycle, a new CSA also requires review of whether the system authorization still covers the changed use.

Use references to agency records. This page is a working aid, not the official repository. Answers stay in this browser session unless you choose browser storage or export them. Nothing entered here is sent to a server.

01 RMF · Prepare

Define the work, information, and scope

Responsible participants: Mission owner · information owner · security, privacy, records, and acquisition staff

Start with the agency's work, not a provider's control package. Describe what people will do, which information will move, and what harm could follow from disclosure, alteration, loss, or misuse. Identify the officials who own the information and accept risk.

Your step 1, with a scope and ownership check added.

What the agency does

- Map creation, collection, processing, storage, sharing, and disposal. Include account details, logs, metadata, exports, integrations, and information sent to other providers. State permitted and prohibited uses.
- Identify applicable legal, privacy, records, accessibility, acquisition, and agency requirements. Security categorization alone does not answer all of these questions.

- Decide whether this use falls within M-24-15 §III and current FedRAMP scope guidance. Record the applicable inclusion or exclusion, the specific offering and deployment, and who approved the determination. Resolve uncertainty with agency officials and FedRAMP.

Why this fits

FISMA protects both agency information and the systems described in the statute. M-24-15 makes scope depend on handling federal information on an agency's behalf, with listed exclusions. A service's commercial status does not answer that scope question.

> **Point of concern · Do not turn "external" into an exemption**
>
> A boundary decision is not a ruling that FISMA, A-130, or FedRAMP cannot apply. The proposal works without asserting that every commercial cloud is outside the statutory system definition. Out-of-scope services still need the protections applicable to the agency's information and use.

Supporting language

LAW

"(A) providing information security protections commensurate with the risk and magnitude of the harm resulting from unauthorized access, use, disclosure, disruption, modification, or destruction of—
"(i) information collected or maintained by or on behalf of the agency; and
"(ii) information systems used or operated by an agency or by a contractor of an agency or other organization on behalf of an agency;

Federal Information Security Modernization Act · 2014-12-18
§2, 44 USC 3554(a)(1)(A); 128 Stat. 3078 · Read original · PDF p. 6

OMB POLICY

FedRAMP's goal is to ensure that Federal information systems and Federal information continue to be protected, even when the agency that owns those systems and information does not have complete control over them. FedRAMP does not apply to every use of an internet based service by a Federal agency. The scope of FedRAMP is cloud computing products and services (such as IaaS, Platform-as-a-Service (PaaS), and SaaS) that create, collect, process, store, or maintain Federal information on behalf of a Federal agency, and that are not otherwise specified as out of scope below.

Modernizing the Federal Risk and Authorization Management Program (FedRAMP) · 2024-07-25
§III, p. 5; exclusions and unclassified/non-NSS limit follow · Read original · PDF p. 5

Record 1 · Define the work, information, and scope

Work and limits

What task, users, and uses are allowed? What is prohibited?

Working example only.
Agency control owner: review team.
<svg onload=alert(1)> must remain text.

Information and flows

Information types, origins, recipients, processing, storage, logs, exports, retention, and disposal. Identify the responsible information owner.

Not recorded.

Scope and applicable obligations

Record the FedRAMP scope provision, offering/version, inclusion or exclusion rationale, other obligations, reviewer, and date.

Not recorded.

02 RMF · Categorize

Categorize information and the agency system

Responsible participants: Information owner · system owner · authorizing official or delegate

Assess confidentiality, integrity, and availability separately for each information type. Then categorize the agency system that will support the work. Record the harm behind each rating.

Your steps 1–2, keeping the information and system decisions distinct.

What the agency does

- Use FIPS 199 and relevant SP 800-60 information-type guidance. Consider mission impact, people affected, aggregated information, and system processing needs. Public information can still require strong integrity and availability protection.
- Derive the system's security category from its information types, taking the highest impact for each objective. FIPS 200 then uses the system impact level in baseline selection.

- Document and obtain the required agency review of the categorization. Revisit it if the design, information, or use changes. Assess privacy and other risks alongside the security category.

Why this fits

FISMA §3554(a)(2) connects harm assessment to protection levels and implementation. FIPS 199 supplies separate information-type and system categories; FIPS 200 connects the system category to control selection.

> **Point of concern · A certification class is not a FIPS category**
>
> Do not choose the agency's impact level to match an available service or its FedRAMP certification class. Current FedRAMP guidance distinguishes assurance classes from the agency's security categorization.

Supporting language

LAW

"(2) ensure that senior agency officials provide information security for the information and information systems that support the operations and assets under their control, including through—
"(A) assessing the risk and magnitude of the harm that could result from the unauthorized access, use, disclosure, disruption, modification, or destruction of such information or information systems;
"(B) determining the levels of information security appropriate to protect such information and information systems in accordance with standards promulgated under section 11331 of title 40, for information security classifications and related requirements;
"(C) implementing policies and procedures to cost-effectively reduce risks to an acceptable level; and
"(D) periodically testing and evaluating information security controls and techniques to ensure that they are effectively implemented;

Federal Information Security Modernization Act · 2014-12-18
44 USC 3554(a)(2); 128 Stat. 3078 · Read original · PDF p. 6

MANDATORY STANDARD

The security category of an information type can be associated with both user information and system information3 and can be applicable to information in either electronic or non-electronic form. It can also be used as input in considering the appropriate security category of an information system (see description of security categories for information systems below).

Establishing an appropriate security category of an information type essentially requires determining the potential impact for each security objective associated with the particular information type.

FIPS 199: Security Categorization · 2004-02-01
§3, printed p. 3 · Read original · PDF p. 7

MANDATORY STANDARD

Determining the security category of an information system requires slightly more analysis and must consider the security categories of all information types resident on the information system.

FIPS 199: Security Categorization · 2004-02-01
§3, printed p. 4 · Read original · PDF p. 8

MANDATORY STANDARD

For an information system, the potential impact values assigned to the respective security objectives (confidentiality, integrity, availability) shall be the highest values (i.e., high water mark) from among those security categories that have been determined for each type of information resident on the information system.

FIPS 199: Security Categorization · 2004-02-01
§3, printed p. 4 · Read original · PDF p. 8

FEDRAMP PROGRAM GUIDANCE

Certification Classes describe the amount and frequency of assurance information available. They do not replace the agency's security categorization or risk decision.

Initial Agency Authorization · Retrieved 2026-10-26
§2, Compare FedRAMP Certified services · Read original

Record 2 · Categorize information and the agency system

Information-type ratings

For each type: confidentiality / integrity / availability impact; concrete harm; rationale; approving official.

Not recorded.

System category and approval

System name, impact by objective, overall impact, aggregation considerations, approval/date, and separate privacy risks.

Not recorded.

03 RMF · Prepare + Select

Set the boundary and allocate controls

Responsible participants: System owner · security/privacy architects · common control providers

Describe a real agency system: its people, procedures, technology, and dependencies. Select and tailor controls for that system. Allocate each protection to the agency, a common control provider, an external service, or a combination.

Your step 2, with architecture and shared responsibilities made explicit.

What the agency does

- Draw the agency authorization boundary, provider certification boundary, and information exchanges. Explain which components are included, which services are external, and how the agency depends on them. Boundaries can differ without creating a gap in responsibility.
- Select the applicable baseline from SP 800-53B, use the current SP 800-53 catalog, and document tailoring, parameters, supplemental controls, and privacy requirements. FIPS 200's older citation to SP 800-53 is read with its instruction to use the current publication as amended.
- Define required capabilities before comparing providers: identity, access, logging, recovery, data protection, incident coordination, and other needs. Record the customer work necessary to use provider capabilities. Revisit the design when a service cannot support a necessary capability.

Why this fits

RMF §2.5 defines the boundary around management and responsibilities. Task S-3 allocates controls to system elements and the environment. SA-9 supplies external-service oversight and monitoring requirements within this wider control set.

> **Point of concern · Neither the provider nor an empty container is the agency system**
>
> Do not copy a provider's entire system into an agency SSP. Do not invent a nominal enclosing system just to avoid describing the actual use. For a simple SaaS use, the agency's accounts, configurations, information handling, personnel, and procedures still need a meaningful boundary and authorization path.

Supporting language

NIST GUIDANCE

The authorization boundary establishes the scope of protection for an information system (i.e., what the organization agrees to protect under its direct management or within the scope of its responsibilities).41 The authorization boundary includes the people, processes, and information technologies (i.e., system elements) that are part of each system supporting the organization's missions and business functions.

SP 800-37 Rev. 2: Security and Privacy RMF · 2018-12-20
§2.5, printed p. 17; see footnote 42 on direct management · Read original · PDF p. 36

MANDATORY STANDARD

Organizations must meet the minimum security requirements in this standard by selecting the appropriate security controls and assurance requirements as described in NIST Special Publication 800-53, Recommended Security Controls for Federal Information Systems.5 The process of selecting the appropriate security controls and assurance requirements for organizational information systems to achieve adequate security6 is a multifaceted, risk-based activity involving management and operational personnel within the organization. Security categorization of federal information and information systems, as required by FIPS Publication 199, is the first step in the risk management process.7 Subsequent to the security categorization process, organizations must select an appropriate set of security controls for their information systems that satisfy the minimum security requirements set forth in this standard. The selected set of security controls must include one of three, appropriately tailored8 security control baselines from NIST Special Publication 800-53 that are associated with the designated impact levels of the organizational information systems as determined during the security categorization process.

FIPS 200: Minimum Security Requirements · 2006-03-09
§4, printed p. 4; footnote 5 requires the current SP 800-53, as amended · Read original · PDF p. 10

NIST GUIDANCE

This publication provides security and privacy control baselines for the Federal Government. There are three security control baselines (one for each system impact level—low-impact, moderate-impact, and high-impact), as well as a privacy baseline that is applied to systems irrespective of impact level. In addition to the control baselines, this publication provides tailoring guidance and a set of working assumptions that help guide and inform the control selection process.

SP 800-53B: Control Baselines · 2020-10-01
Abstract, printed p. ii; October 2020, includes December 10, 2020 update · Read original · PDF p. 4

NIST GUIDANCE

The organization designates controls as system-specific, hybrid, or common, and allocates the controls to the system elements (i.e, machine, physical, or human elements) responsible for providing a security or privacy capability. Controls are allocated to a system or an organization consistent with the organization's enterprise architecture and security or privacy architecture and the allocated security and privacy requirements. Not all controls need to be allocated to every system element. Controls providing a specific security or privacy capability are only allocated to system elements that require that capability.

SP 800-37 Rev. 2: Security and Privacy RMF · 2018-12-20
Task S-3, printed p. 53 · Read original · PDF p. 72

NIST GUIDANCE

Control:
a. Require that providers of external system services comply with organizational security and privacy requirements and employ the following controls: [Assignment: organization-defined controls];
b. Define and document organizational oversight and user roles and responsibilities with regard to external system services; and
c. Employ the following processes, methods, and techniques to monitor control compliance by external service providers on an ongoing basis: [Assignment: organization-defined processes, methods, and techniques].

SP 800-53 Rev. 5: Security and Privacy Controls · 2020-09-01
SA-9(a)–(c), printed p. 271; Rev. 5, December 2020 update · Read original · PDF p. 298

Record 3 · Set the boundary and allocate controls

Boundary and dependencies

Describe or link the diagram: agency resources, provider offering, interfaces, inherited services, and exclusions with reasons.

Not recorded.

Control allocation and tailoring

For each requirement/control: rationale, parameter, agency/provider/shared owner, implementation, evidence needed, and monitoring owner. Record SA-9 oversight and monitoring assignments.

Not recorded.

04 RMF · Select + risk assessment

Reuse FedRAMP evidence and decide whether the service fits

Responsible participants: System owner · assessors · security/privacy staff · acquisition team

Compare candidate services against the agency's needs. Reuse the FedRAMP package for the provider's assessed work. Spend agency effort on whether the specific offering, configuration, dependencies, and proposed use meet the mission and protection needs.

Your step 3, with the statutory presumption of adequacy applied.

What the agency does

- Confirm the exact certified or authorized offering, boundary, included features, status, applicable assurance information, and ongoing evidence. Check whether the planned deployment is covered. Use current FedRAMP guidance for the assurance evidence; do not invent a certification-class-to-FIPS-impact equivalence. A related product name or marketplace entry is not enough.
- Review secure configuration guidance, responsibility allocations, assessment findings, ongoing reports, inherited services, and constraints. Distinguish provider evidence, agency implementation evidence, and unanswered questions.
- Use the presumption of adequacy. Ask clarifying questions. If added provider requirements or information are needed, record the demonstrable need and use the required agency determination and FedRAMP notification procedures. Collaborate with FedRAMP on package conflicts; document a wholly or substantially deficient package determination where applicable.
- Select a service that supports the required capabilities, or revise the architecture or use. Track unresolved issues and acquisition conditions. Selection is not permission to begin processing information.

Why this fits

44 USC 3613(a)(3) requires reuse to the extent practicable. Section 3613(e) presumes the assessment adequate while preserving FISMA duties and demonstrable additional needs. M-24-15 §IV and current Agency Use rules implement that balance.

Point of concern · Do not recreate the provider assessment under SA-9

Selecting controls for the agency system does not justify sending the provider a new agency checklist. Separate a customer-side configuration or integration need from an additional provider security requirement. Use the current FedRAMP process for the latter; a routine preference is not automatically a demonstrable need.

Supporting language

LAW

"(3) to the extent practicable, for any cloud computing product or service the agency seeks to authorize that has received a FedRAMP authorization, use the existing assessments of security controls and materials within any FedRAMP authorization package for that cloud computing product or service;

FedRAMP Authorization Act in P.L. 117-263 · 2022-12-23
44 USC 3613(a)(3); 136 Stat. 3453 · Read original · PDF p. 1059

LAW

"(e) PRESUMPTION OF ADEQUACY.—
"(1) IN GENERAL.—The assessment of security controls and materials within the authorization package for a FedRAMP authorization shall be presumed adequate for use in an agency authorization to operate cloud computing products and services.
"(2) INFORMATION SECURITY REQUIREMENTS.—The presumption under paragraph (1) does not modify or alter—
"(A) the responsibility of any agency to ensure compliance with subchapter II of chapter 35 for any cloud computing product or service used by the agency; or
"(B) the authority of the head of any agency to make a determination that there is a demonstrable need for additional security requirements beyond the security requirements included in a FedRAMP authorization for a particular control implementation.

FedRAMP Authorization Act in P.L. 117-263 · 2022-12-23
44 USC 3613(e)(1)–(2); 136 Stat. 3454 · Read original · PDF p. 1060

OMB POLICY

To that end, if a given cloud product or service has a FedRAMP authorization at a given FIPS 199 impact level, the Act requires that agencies must presume the security assessment documented in the authorization package is adequate for their use in issuing an authorization to operate at or below that FIPS 199 impact level.

Modernizing the Federal Risk and Authorization Management Program (FedRAMP) · 2024-07-25
§IV(a), p. 6; continued on p. 7: authorization must be actively maintained · Read original · PDF p. 6

FEDRAMP PROGRAM RULES

Agencies MUST NOT require additional information or materials from FedRAMP Certified cloud service offerings beyond those required by FedRAMP UNLESS the head of the agency or an authorized delegate determines there is a demonstrable need and notifies FedRAMP; this does not apply to seeking clarification or asking general questions about FedRAMP Certification Data.

Agency Use rules · Retrieved 2026-10-26
AGU-AGC-NAR; demonstrable need, notification, clarification exception · Read original

Record 4 · Reuse FedRAMP evidence and decide whether the service fits

Selected offering and evidence

Provider/service/version/deployment, package identifier and date, status/class or impact basis as applicable, features and inherited services covered, reviewers, and evidence links.

Not recorded.

Fit, gaps, and reuse

Required capability → provider evidence → agency configuration/work → residual gap/risk. Identify stale or missing evidence.

Not recorded.

Additional provider requirements, if any

Distinguish clarification from added requirements. State demonstrable need, determining official, notification/reference, package conflicts, and resolution. Enter “none” when appropriate.

Not recorded.

05 RMF · Proposed FedRAMP CSA process · supports Select and Implement

Perform and sign a Cloud Service Authorization

Responsible participants: Agency CSA signing official · system owner · acquisition, security, and privacy staff

Under this proposal, the agency follows a new FedRAMP-specific process to authorize a cloud service for use by its agency information system. The result is a signed Cloud Service Authorization (CSA). The agency references that CSA from its system documentation for SA-9, SA-4, and other applicable controls.

Your revised step 4: a distinct, signed CSA under a new FedRAMP process, separate from the agency system ATO.

What the agency does

- Use the FedRAMP-defined CSA procedure to review the service, reuse provider assessment evidence, resolve agency-specific requirements, and make a service-level risk decision for the identified agency system. This is an agency CSA, distinct from the provider's FedRAMP authorization or certification.
- Document the service and approved information/use, required protections, provider and agency responsibilities, configuration and integration conditions, evidence relied on, residual risks, monitoring duties, and review or termination triggers. Identify the signing official and authority required by the new process.
- Set agreements for security/privacy, incidents, recovery, evidence access, information exchanges, records, retention/deletion, and exit. Reference the signed CSA by identifier and version from SA-9 external-service documentation, SA-4 acquisition documentation, and other applicable controls such as CA-3. Each control entry should still explain its own implementation and responsibilities.
- Issue a distinct signed CSA decision and retain its supporting record. Link it to the agency system and its ATO package. For a new system, the CSA can precede the completed system ATO, with operational use contingent on that ATO. For an already authorized system, perform the CSA within its lifecycle and determine whether the proposed use requires an ATO update or other agency risk decision.

Why this fits

The Act's process, template, and reuse authorities and M-24-15 provide a basis for proposing this procedure. A-130 and SA-4, SA-9, and CA-3 support the agreements, responsibilities, and evidence it would document. The cited materials do not themselves establish this distinct signed agency CSA; FedRAMP would need to adopt and define it through the applicable governance process.

> **Point of concern · FedRAMP must define the new decision, not just its name**
>
> The new process needs a defined scope, signing authority, decision standard, required evidence, signature and record requirements, monitoring and revocation rules, and relationship to the system ATO. It must preserve the statutory presumption of adequacy and agency FISMA duties. SA-9 and SA-4 document the CSA's implementation; they do not independently create the CSA process.

Supporting language

OMB POLICY

1) Ensure that terms and conditions in contracts and other agreements involving the creation, collection, use, processing, storage, maintenance, dissemination, disclosure, and disposal of Federal information, incorporate security and privacy requirements and are sufficient to enable agencies to meet Federal and agency-specific requirements pertaining to the protection of Federal information;

A-130: Managing Information as a Strategic Resource · 2016-07-28
Appendix I §4(j)(1), printed p. 14 · Read original · PDF p. 51

NIST GUIDANCE

Control: Include the following requirements, descriptions, and criteria, explicitly or by reference, using [Selection (one or more): standardized contract language; [Assignment: organization-defined contract language]] in the acquisition contract for the system, system component, or system service:
a. Security and privacy functional requirements;
b. Strength of mechanism requirements;
c. Security and privacy assurance requirements;
d. Controls needed to satisfy the security and privacy requirements.
e. Security and privacy documentation requirements;
f. Requirements for protecting security and privacy documentation;
g. Description of the system development environment and environment in which the system is intended to operate;
h. Allocation of responsibility or identification of parties responsible for information security, privacy, and supply chain risk management; and
i. Acceptance criteria.

SP 800-53 Rev. 5: Security and Privacy Controls · 2020-09-01
SA-4(a)–(i), printed p. 252; control text, not the later revised discussion · Read original · PDF p. 279

NIST GUIDANCE

b. Document, as part of each exchange agreement, the interface characteristics, security and privacy requirements, controls, and responsibilities for each system, and the impact level of the information communicated; and
c. Review and update the agreements [Assignment: organization-defined frequency].

SP 800-53 Rev. 5: Security and Privacy Controls · 2020-09-01
CA-3(b)–(c), printed p. 87; subsection (a) requires approval and management of the exchange through agreements · Read original · PDF p. 114

Record 5 · Perform and sign a Cloud Service Authorization

Agreements and control references

Contract/agreement reference → requirement → responsible party → evidence/remedy. Map the CSA identifier and version to SA-9, SA-4, CA-3, and other applicable agency-system control entries.

Not recorded.

CSA decision and signed record

Status (draft, approved, denied, or deferred); CSA ID/version; FedRAMP CSA procedure/version; agency system ID; service and approved information/use; requirements, responsibilities, evidence, residual risk, conditions and monitoring; signing official/authority, signature/date and signed-record location; linked system ATO. This worksheet does not sign the CSA.

Not recorded.

06 RMF · Implement + Assess

Configure, integrate, and assess the agency's implementation

Responsible participants: System owner · implementers · control assessors

Build or configure the agency's use, implement customer responsibilities, and assess that implementation. Reuse provider evidence where it applies. Check that the combined arrangement works, not merely that each party has documents.

Your step 5, with implementation evidence separated from provider evidence.

What the agency does

- Implement the approved design, agency controls, shared controls, configuration settings, access rules, training, and operating procedures. Record actual implementation in the agency security/privacy plans and link SA-9, SA-4, and other applicable entries to the signed CSA. Reconcile implementation changes with CSA conditions before operational use.
- Test relevant integrations and agency responsibilities: account lifecycle, privileged access, information sharing, log delivery, incident coordination, recovery, and exit capabilities. Confirm that claimed inherited capabilities are available in the selected service and deployment.

- Prepare assessment results, remediation plans, and residual-risk analysis. Link provider findings that affect agency risk to the agency decision; do not duplicate every provider POA&M as if it were agency work.
- Revisit the design or service selection if the combined controls are inadequate. Use only an appropriately approved test or pilot arrangement before operational authorization.

Why this fits

FISMA requires implementation and periodic evaluation. A-130 requires contractor oversight. NIST's reuse guidance still requires consideration of integration risk, and current FedRAMP guidance tells agencies to test their implementation.

> **Point of concern · A signed CSA does not authorize an unfinished agency system**
>
> The CSA is a distinct service decision under the proposed FedRAMP process. The agency still has to implement and assess the system that uses the service. Operational use must be covered by the agency system's ATO; a CSA alone does not supply that authorization. A limited pilot has its own conditions.

Supporting language

> **OMB POLICY**
>
> 2) Provide oversight of information systems used or operated by contractors or other entities on behalf of the Federal Government or that collect or maintain Federal information on behalf of the Federal Government, to include: a) Documenting and implementing policies and procedures for information security and privacy oversight, to include ensuring appropriate vetting and access control processes for contractors and others with access to information systems containing Federal information; b) Ensuring that security and privacy controls of such information systems and services are effectively implemented and comply with NIST standards and guidelines and agency requirements; c) Ensuring that these information systems are included in the agency's inventory of information systems; d) Ensuring that the interface characteristics, security requirements, and the nature of the information communicated is documented for each interface between these systems and agency-owned or operated information systems;
>
> A-130: Managing Information as a Strategic Resource · 2016-07-28
> Appendix I §4(j)(2)(a)–(d), printed p. 14 · Read original · PDF p. 51

NIST GUIDANCE

If the customer organization plans to integrate the shared system, application, or service with one or more of its systems, the customer organization considers the risk in doing so.

SP 800-37 Rev. 2: Security and Privacy RMF · 2018-12-20
Appendix F, printed p. 145 · Read original · PDF p. 164

FEDRAMP PROGRAM GUIDANCE

Configure the service according to the approved design and the Secure Configuration Guide. Implement the agency controls, common controls, integrations, training, and procedures. Test the agency's implementation. Confirm that identity integration works, required logs reach the SIEM, security settings remain in place, and agency staff can carry out incident and recovery procedures. Reuse the FedRAMP Certification Package for evidence about the provider's capabilities.

Initial Agency Authorization · Retrieved 2026-10-26
§4, Configure and assess the agency's use · Read original

Record 6 · Configure, integrate, and assess the agency's implementation

Agency implementation and assessment

Implemented settings/procedures, evidence links, assessor/date, provider evidence reused, inherited capabilities checked, and integration tests/results.

Not recorded.

Findings and risk response

Finding → affected mission/information → owner → mitigation or acceptance → due date.
Link provider remediation and record any agency compensating actions.

Not recorded.

07 RMF · Authorize

Authorize the agency information system under FISMA

Responsible participants: Agency authorizing official

The agency authorizing official makes the ATO decision for the federal information system as a whole. The system authorization package incorporates the signed CSA for each cloud service, along with evidence for agency controls, integrations, and the rest of the system.

Your step 5: the agency system ATO remains a separate decision under FISMA, supported by the signed CSA records.

What the agency does

- Complete the agency system assessment and authorization package under the applicable FISMA, OMB, and NIST processes. Identify the system boundary, mission and information, all relevant controls, integration evidence, residual risks, and the signed CSA records being relied on.
- Issue or update the agency system ATO through agency procedures. Reference the CSA identifiers and versions and ensure their conditions are reflected in the system design, SA-9, SA-4, other applicable controls, and monitoring plan. The CSA and ATO remain distinct signed decisions with different scopes.
- Keep existing terminology clear. M-24-15 and SP 800-37 also describe an ATU reuse route, quoted below for comparison. This proposal uses a system ATO plus a new CSA; it does not rename an ATU as a CSA or claim that the existing ATU provisions already establish the new process.
- Submit the agency ATO letter and supplementary information to FedRAMP as currently required. Any CSA-specific submission or registration requirement would need to be established in the new process. If system risk is unacceptable, resolve the issue, restrict the use, or deny the ATO even if a service has a CSA.

Why this fits

A-130 assigns formal system authorization to senior federal officials. The FedRAMP Act preserves agency FISMA responsibility and requires submission of the agency ATO based on FedRAMP authorization. The proposed CSA supplies a separate service decision and evidence within that system lifecycle; it does not discharge the system-level duties.

> **Point of concern · Separate decisions should reuse the same evidence**
>
> The CSA addresses the cloud service's approved use, requirements, and responsibilities. The ATO addresses the agency system as a whole, including integration and combined risk. FedRAMP would need to make the distinction operational so agencies can reference CSA work in the ATO package without repeating the provider assessment or issuing an ATO for the provider's offering.

Supporting language

OMB POLICY

1) Designate senior Federal officials to formally authorize an information system to operate and authorize agency-designated common controls for use;

A-130: Managing Information as a Strategic Resource · 2016-07-28
Appendix I §4(d)(1), printed p. 7 · Read original · PDF p. 44

OMB POLICY

Agencies leverage the FedRAMP authorization package to issue their own “authorization to operate” (ATO) or “authorization to use” (ATU). FedRAMP does not replace other legal, Executive Order, regulatory, or OMB-issued compliance requirements for areas such as information management, records management, privacy, and cybersecurity.

Modernizing the Federal Risk and Authorization Management Program (FedRAMP) · 2024-07-25
§IV footnote 7, printed p. 6 · Read original · PDF p. 6

NIST GUIDANCE

An authorization to use is employed when an organization (hereafter referred to as the customer organization) chooses to accept the information in an existing authorization package produced by another organization (either federal or nonfederal) for an information system that is authorized to operate by a federal entity (referred to as the provider organization).140 The authorization to use is a mechanism to promote reciprocity for systems under the purview of different authorizing officials. An authorization to use is issued by an authorizing official from the customer organization instead of an authorization to operate. The official issuing an authorization to use has the same level of responsibility and authority for risk management as an authorizing official issuing an authorization to operate or a common control authorization.

SP 800-37 Rev. 2: Security and Privacy RMF · 2018-12-20
Appendix F, printed p. 144; footnotes 140–141 · Read original · PDF p. 163

NIST GUIDANCE

A customer organization can issue an authorization to use only after a valid authorization to operate has been issued by another federal entity (i.e., the provider organization).

SP 800-37 Rev. 2: Security and Privacy RMF · 2018-12-20
Appendix F, p. 144; footnote 142 recognizes a GSA FedRAMP provisional ATO · Read original · PDF p. 163

NIST GUIDANCE

The authorization to use is a streamlined version of the authorization to operate and includes: • A risk acceptance statement; and • Time- or event-driven triggers for review of the security and privacy posture of the provider organization shared cloud or system, application, or service (if any).

SP 800-37 Rev. 2: Security and Privacy RMF · 2018-12-20
Appendix F, printed p. 148 · Read original · PDF p. 167

LAW

"(c) SUBMISSION OF AUTHORIZATIONS TO OPERATE REQUIRED.— Upon issuance of an agency authorization to operate based on a FedRAMP authorization, the head of the agency shall provide a copy of its authorization to operate letter and any supplementary information required pursuant to section 3609(a) to the Administrator.

FedRAMP Authorization Act in P.L. 117-263 · 2022-12-23
44 USC 3613(c); 136 Stat. 3454 · Read original · PDF p. 1060

FEDRAMP PROGRAM RULES

Agencies MUST notify FedRAMP upon authorizing the use of a cloud service within the scope of FedRAMP, supplying at least the following information: A copy of the agency's Authorization to Operate letter for the information system leveraging the cloud service, following agency policy and templates. All other supplemental information requested in the Submit an ATO Letter form by FedRAMP.

Agency Use rules · Retrieved 2026-10-26
AGU-AGC-NAA; current page labels rules required, effective July 4, 2026 · Read original

Record 7 · Authorize the agency information system under FISMA

Agency system ATO and CSA references

System/package ID; ATO official, decision/date and signed-record location; approved scope, information, configuration, residual risk and conditions; linked CSA IDs/versions and SA-9/SA-4/other control references; review triggers. Record denial, deferral, or the treatment of a change to an existing ATO.

Not recorded.

ATO submission and proposed CSA reporting

Date/reference and agency ATO letter/supplementary information supplied to FedRAMP, or why not applicable. Separately identify any CSA reporting that the new procedure would require; do not assume it replaces the ATO submission.

Not recorded.

08 RMF · Monitor + disposal

Monitor both, respond to change, and plan exit

Responsible participants: System owner · monitoring staff · authorizing official · service contacts

Use FedRAMP's ongoing service evidence in the agency's continuous monitoring program. Monitor the agency's configuration, accounts, integrations, and procedures too. Use both streams to maintain the CSA's conditions and inform the agency system's ongoing ATO decision.

Your step 6, with feedback, change response, and exit added.

What the agency does

- Specify evidence sources, review cadence, owners, escalation paths, and durable contacts. Include relevant inherited service evidence. Review provider reports and findings for their effect on the agency's authorized use.
- Monitor customer controls, configuration drift, logs, account changes, privacy/records handling, incidents, and agency remediation. Record what the agency accepted, changed, or escalated in response to service evidence.
- Reassess when information, mission, deployment, features, integrations, provider posture, certification status, or threats change. Notify FedRAMP and the provider when required; decide whether to continue, restrict, suspend, or end use. Under the proposed process, record any CSA revision or revocation and its effect on the system ATO.
- Plan export, retention, deletion, account closure, key handling, transition, and evidence of completion before exit. Disposal is part of the information lifecycle, not a task left to the provider's default retention policy.

Why this fits

SA-9 requires ongoing external-provider monitoring and leaves risk with the authorizing official. M-24-15 supplies a shared monitoring framework; current FedRAMP guidance expressly says it does not replace agency monitoring.

Point of concern · Two evidence streams must not become two disconnected programs

FedRAMP monitoring is not a transfer of the agency's risk responsibility. Equally, agency monitoring should not recreate the provider's program or demand advance approval for every service change. Monitor the provider's change process and the effects on the agency's use, following current FedRAMP procedures.

Supporting language

NIST GUIDANCE

Discussion: External system services are provided by an external provider, and the organization has no direct control over the implementation of the required controls or the assessment of control effectiveness. Organizations establish relationships with external service providers in a variety of ways, including through business partnerships, contracts, interagency agreements, lines of business arrangements, licensing agreements, joint ventures, and supply chain exchanges. The responsibility for managing risks from the use of external system services remains with authorizing officials. For services external to organizations, a chain of trust requires that organizations establish and retain a certain level of confidence that each provider in the consumer-provider relationship provides adequate protection for the services rendered. The extent and nature of this chain of trust vary based on relationships between organizations and the external providers. Organizations document the basis for the trust relationships so that the relationships can be monitored. External system services documentation includes government, service providers, end user security roles and responsibilities, and service-level agreements. Service-level agreements define the expectations of performance for implemented controls, describe measurable outcomes, and identify remedies and response requirements for identified instances of noncompliance.

SP 800-53 Rev. 5: Security and Privacy Controls · 2020-09-01
SA-9 discussion, printed p. 271 · Read original · PDF p. 298

OMB POLICY

For all FedRAMP authorized products and services, the FedRAMP PMO will provide a standard level of continuous monitoring support. The FedRAMP PMO will set this standard level of monitoring support by analyzing and identifying the highest-impact controls for ensuring the security of FedRAMP products and services. It will provide recommendations for the supported monitoring levels to the FedRAMP Board for review, feedback, and approval. When finalized, the FedRAMP PMO will provide supported monitoring to all agency customers of authorized FedRAMP products and services. The monitoring data provided to agencies will support agencies in making risk determinations for authorized cloud computing products and services, including when the CSO is leveraged within another information system.

Modernizing the Federal Risk and Authorization Management Program (FedRAMP) · 2024-07-25
§VI, p. 14 · Read original · PDF p. 14

OMB POLICY

Redesigns the process for overseeing changes to cloud computing products and services to one that primarily monitors the CSP's change process itself, rather than individual changes. Once a CSO is authorized, the FedRAMP process should generally empower CSPs to deploy changes and fixes at their own pace, without requiring advance approval from FedRAMP or an authorizing official for individual changes to existing FedRAMP authorized products and services;

Modernizing the Federal Risk and Authorization Management Program (FedRAMP) · 2024-07-25
§VI, p. 13 · Read original · PDF p. 13

FEDRAMP PROGRAM GUIDANCE

FedRAMP provides a minimum standard level of continuous monitoring focused on whether the cloud service provider continues to meet the requirements needed to maintain FedRAMP Certification. This is not a complete substitute for agency monitoring. Agencies should treat FedRAMP's monitoring as shared provider evidence. The agency still needs to decide how that evidence affects the agency authorization, whether additional agency action is needed, and whether the cloud service offering remains appropriate for the agency's use.

Ongoing Agency Authorization · Retrieved 2026-10-26
FedRAMP's Standard Continuous Monitoring · Read original

Record 8 · Monitor both, respond to change, and plan exit

Monitoring plan

Evidence/report → review frequency → reviewer → trigger/threshold → action/official.
Include provider and agency sources, inherited services, and continuity of contacts.

Long-answer print check. Long-answer print check. Long-answer print check.

Long-answer print check. Long-answer print check. Long-answer print check.

Return to workbook controls

Sources, editions, and limits

Quoted passages retain the source wording. PDF line wrapping and line-end hyphenation are normalized; paragraph breaks are added for readability. Locators identify the printed section and original PDF page. The analysis and workbook prompts are this report's interpretation and proposal.

Currency: reviewed October 26, 2026. The statutory quotations come from the 2014 and 2022 enacted laws, checked against the site's retained current-law collection (OLRC release 119-118, through September 30, 2026). This is not a claim to have audited every later enactment. A-130 is the 2016 revision; M-24-15 is July 25, 2024. SP 800-37 Rev. 2 is December 2018. The SP 800-53 Rev. 5 quotes use the December 2020 update; NIST's August 2025 Release 5.2.0 changes do not alter SA-9 or the SA-4 control statement quoted here. Current baselines are in SP 800-53B and its applicable updates.

Program guidance: the five current FedRAMP pages were captured October 26, 2026. The Agency Use page labels its rules required, with July 4, 2026 applicability dates. The local FedRAMP MCP snapshot was older and marked some rules as placeholders; the published page is the basis for the program-status descriptions here. See the current scope guidance for detailed exclusions and examples. National-security and classified systems are outside this workbook's scope.

See the information and systems history for the earlier law, comments, and changes. This page concentrates on the proposed implementation. Download quotations · Download source metadata

FIPS 200: Minimum Security Requirements

Mandatory standard · 2006-03-09

Official source · Retained original

Federal Information Security Modernization Act

Law · 2014-12-18

Official source · Retained original

A-130: Managing Information as a Strategic Resource

OMB policy · 2016-07-28

Official source · Retained original

SP 800-37 Rev. 2: Security and Privacy RMF

NIST guidance · 2018-12-20

Official source · Retained original

Modernizing the Federal Risk and Authorization Management Program (FedRAMP)

OMB policy · 2024-07-25

Official source · Retained original

FedRAMP Authorization Act in P.L. 117-263

Law · 2022-12-23

Official source · Retained original

Using a FedRAMP Certified Cloud Service

FedRAMP program guidance · Retrieved 2026-10-26

Official source · Retained original

Initial Agency Authorization

FedRAMP program guidance · Retrieved 2026-10-26

Official source · Retained original

Ongoing Agency Authorization

FedRAMP program guidance · Retrieved 2026-10-26

Official source · Retained original

Agency Use rules

FedRAMP program rules · Retrieved 2026-10-26

Official source · Retained original

FedRAMP scope

FedRAMP program guidance · Retrieved 2026-10-26

Official source · Retained original

FIPS 199: Security Categorization

Mandatory standard · 2004-02-01

Official source · Retained original

SP 800-53 Rev. 5: Security and Privacy Controls

NIST guidance · 2020-09-01

Official source · Retained original

SP 800-53B: Control Baselines

NIST guidance · 2020-10-01

Official source · Retained original